SIMATS ENGINEERING

ASSESSMENT TOOL 3 — Penetration Testing Task

Course Name: Ethical Hacking	**Course Code:** ITA14
Name: PRANOV RAAJ	**Reg No:** 192372355
CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)	

Q4. Analyzing Scan Results: Open, Closed, and Filtered Port States

During a port scan, Nmap classifies every probed port into one of several states based on the response (or lack of response) it receives. Understanding what each state means is essential for correctly interpreting a scan and deciding what follow-up action is needed.

Port State	Meaning	What It Indicates to a Tester
Open	A service is actively listening on that port and responded to the probe (e.g., SYN-ACK for TCP).	A live, reachable service exists — the primary target for service/version enumeration and vulnerability mapping.
Closed	The port is reachable (the host responded) but no service is listening — the host replies with a RST.	The host is up and the network path is clear, but this specific port has nothing running on it right now.
Filtered	No response, or an ICMP unreachable error, was received — Nmap cannot determine if the port is open or closed.	A firewall, ACL, or packet-filtering device is blocking the probe; further techniques (ACK/FIN/Idle scans, -Pn) are needed to learn more.

Open

A port is reported Open when the target actively responds to the probe in a way that confirms a service is listening — for a SYN scan this means a SYN-ACK was received. This is the most actionable state for a penetration tester, since it identifies a live service that can be fingerprinted (service/version detection), tested for known vulnerabilities, and, if authorized, targeted for exploitation.

Closed

A port is Closed when the host is reachable and responds to the probe, but explicitly indicates that nothing is listening — for TCP this is signaled by a RST packet in reply to the SYN. This confirms the host itself is alive and the network path is not being filtered, but that particular port is not currently in use. Closed ports still have value during an assessment because they confirm the host is up and help distinguish a truly down host from one that is simply not running many services.

Filtered

A port is Filtered when Nmap cannot determine whether it is open or closed because no response was received, or because an ICMP "destination unreachable" error was returned. This is the classic signature of a firewall, router ACL, or IPS silently dropping or blocking the probe rather than letting the target's TCP/IP stack respond naturally. Filtered results require further investigation — techniques such as ACK scans (to map firewall rulesets), FIN/NULL/Xmas scans, Idle scans, or disabling host discovery with -Pn are used to gather additional information when a large proportion of ports come back filtered.

How Nmap Determines Each State (Protocol-Level Analysis)

Nmap does not guess a port's state — it derives it directly from the response defined by RFC 793 (TCP) and RFC 768/792 (UDP/ICMP) for the specific probe type sent:

- SYN scan (-sS): sends a bare SYN. SYN/ACK in reply → Open. RST in reply → Closed. No response after retransmission, or an ICMP type 3 (destination unreachable, code 1/2/3/9/10/13) → Filtered.
- TCP Connect scan (-sT): identical logic to SYN scan, but the OS completes the full handshake using the connect() system call rather than Nmap crafting raw packets, so the same Open/Closed/Filtered outcomes apply, just observed indirectly through socket errors.
- UDP scan (-sU): no handshake exists for UDP, so state inference is weaker — any response payload → Open; ICMP port-unreachable (type 3, code 3) → Closed; no response at all → Open|Filtered, because Nmap cannot tell whether the packet was silently dropped by a filter or simply ignored by an application that received it but chose not to reply.
- ACK scan (-sA): used only to map firewall state, not real port status — RST in reply → Unfiltered (port is reachable by the firewall, real state unknown); no response/ICMP error → Filtered.

Case Study: Applying This to the Attached Scan

The attached scan (Fig 1) ran nmap -Pn -sS --top-ports 100 against 192.168.1.100. The -Pn flag skipped host-discovery entirely and forced Nmap to probe all 100 ports regardless of whether a ping response was seen, which is itself a technique for handling hosts that block ICMP (directly relevant to Q1 in this same paper). The result — "Not shown: 100 filtered tcp ports (no-response)" — means every one of the 100 probed ports fell into the Filtered bucket rather than showing a mix of Open/Closed/Filtered. Analytically, this is a strong indicator of a default-deny stateful firewall or an intermediate ACL positioned in front of the host, silently dropping unsolicited SYN packets rather than the host's own TCP stack replying with RSTs for closed ports. If the host's OS itself were simply not running services, the expected response would have been Closed (RST) for unused ports, not silence — so the uniformity of the Filtered result across all 100 ports points to network-level filtering, not an unusually locked-down host.

Recommended Next Steps for This Result

- Re-scan a broader port range and slower timing (-T2, --top-ports 1000 or -p-) in case the firewall is only rate-limiting rather than blocking outright.
- Run an ACK scan (-sA) against the same target to determine whether the filtering device is stateful (blocks everything) or stateless (only blocks certain flag combinations).
- Attempt fragmentation (-f) or a different source port (--source-port 53/443) to test whether the filter trusts specific traffic patterns.
- Cross-check with an internal vantage point (scanning from inside the same network segment) to isolate whether the filtering is host-based or perimeter-based.
- Document the finding as evidence of an active, correctly configured perimeter control — from a defensive standpoint this is a positive security finding, not a vulnerability.

Why This Distinction Matters in Practice

Correctly distinguishing Open, Closed, and Filtered is foundational to every later stage of a penetration test, and getting it wrong has real consequences:

- Misreading Filtered as Closed can cause a tester to wrongly conclude a network has no exposed services, missing a firewall-protected service that may still be reachable through an alternate path (VPN, internal segment, misconfigured rule).

- Misreading Filtered as Open (common with UDP's open|filtered ambiguity) can generate false-positive findings in a report, wasting remediation effort on services that were never actually running.
- Treating Closed ports as 'no risk' ignores that a Closed port today can become Open tomorrow if a service is redeployed — Closed ports are still logged as a baseline for future differential scans.
- Accurately separating these states lets a tester correctly attribute a security posture to either the host configuration (Closed) or the network architecture (Filtered), which changes who is responsible for remediation — the application/system owner vs. the network/firewall team.

Linkage to Vulnerability Assessment and Reporting

In the overall penetration-testing workflow, port-state analysis is the bridge between raw reconnaissance and actionable findings. Open ports feed directly into service/version detection (-sV) and vulnerability correlation against CVE databases. Closed ports establish a reliable baseline of host liveness that can be compared across repeated scans to detect newly deployed services. Filtered ports are documented separately as evidence of the network's defensive controls and are typically noted in the report as 'inconclusive — protected by filtering' rather than being scored as a vulnerability, unless further techniques (ACK/Idle/fragmentation) succeed in revealing the underlying state. Presenting all three states together, with the reasoning behind each classification, gives a client both an accurate risk picture and confidence that the assessment methodology was sound.

Fig 1: SYN scan without host discovery (nmap -Pn -sS --top-ports 100) against 192.168.1.100 — all 100 scanned ports report as filtered (no response), indicating a firewall or packet filter is blocking the probes rather than the host being down.

Code of Conduct

I PRANOV RAAJ (Reg No: 192372355) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: ____________________